

BIS - Zpráva z projektu

xwagne10

December 2022

1 myprog

Program jsem prvně zkusil otevřít, byl jsem přivítán výzvou k zadání hesla. Náhodně jsem zkusil heslo a program poslal na pozadí, protože pohlcuje všemožné signály.

První pokus o získání hesla či tajemství bylo použití linuxového nástroje `strings`, ale ten nenašel nic zajímavého

Stáhl jsem si nástroj Ghidra s dekompilátorem a program otevřel v nástroji. Bylo zapotřebí vyznat se v obfuskovaných indexech uvnitř zanořených kontrolních blocích porovnání hesla znak po znaku. Heslo bylo po analýze `35f887de75` a program vrátil tajemství:

```
Tajemstv_x_5753652def8559cc6150c0b0dfecfe22575dd7cf752c1c3f15753652
```

Během dekompilace jsem oběvil náповědu v -3 césarově šifře:

```
Uhiuhvk brxu dvvhpeohu vnloov wr rewdlq vhfuhw  
Refresh your assembler skills to obtain secret
```

Škoda, že jsem náповědu našel až při dekompilaci, i tak jsem ovšem úkol zvládl.

2 jsapp

V tomto úkolu jsem se věnoval deobfuskaci kódu, dokud jsem nenarazil na porovnávání hesla ve formě plain-text, heslo jsem si následně vypsal do konzole pomocí `console.log(_0x4b336b)` ve funkci `passw`:

```
73b1bcb35
```

Nalezení jména bylo těžší, v kódu se nachází jeho hash a zkusil jsem tedy použít na internetu dostupné rainbow-tables, ovšem neúspěšně. Rovněž jsem dokončil deobfuskaci a nenašel nic dále užitečného. Tak jsem skončil útokem silou na hash v programu Hashcat a za odpoledne našel jméno:

```
user22129
```

Tajemství:

```
Tajemstvi_1_9707e2e6120a96ac30756d3c32d361d1438874bf1b391c706d75e8c1db514572
```

3 library

Z názvu složky a statické knihovny je jasné, že je zapotřebí vytvořit vlastní knihovnu a injektovat vlastní kód. Za tímto účelem soubor `odposlech` přibližuje použití funkce z knihovny. Vlastní knihovna byla napsána s jednou prázdnou funkcí a jednou funkcí vracející hodnotu 123 a přeložena programem `gcc` s parametry `-fPIC` a `-shared`. Po spuštění program vypsal tajemství:

```
Tajemstvi_3_de41cf002d6ef2ae1676b93f9c12bc1dabe1b41ee872a07a11fc50
```

4 korespondence

Prohledáváním serveru byla objevena podezřele pojmenovaná složka `prace` v root adresáři serveru. Tato složka obsahovala rsa klíč, zprávu a složku `mail` s korespondencí. Nad korespondencí byl použit nástroj `xgrep`, jelikož korespondence obsahuje přes 200000 řádků. Takto bylo získáno tajemství, jelikož má daný prefix:

```
tajemstvi_h_7155a291dcf4c45918b26de2571b13a0dffde1109a576863cddbd7b45d95508a
```

5 server2

Korespondence byla stejným způsobem prohledána i pro účely získání IP serveru ke kterému patří rsa klíč ve vnější složce, ovšem bez úspěchu. Z klíče lze base64 dekodovat, že patří uživateli `joe`, tuto informaci lze odhadnout i z podpisu zprávy ve složce `prace`. Bylo tedy provedeno discovery sítě použitím příkazu `arp -a` s výsledkem:

```
server2 (192.168.122.235) at 52:54:00:3a:fb:88 [ether] on enp1s0
? (192.168.122.3) at 52:54:00:53:08:85 [ether] on enp1s0
_gateway (192.168.122.1) at 52:54:00:41:27:d1 [ether] on enp1s0
? (192.168.122.149) at 52:54:00:2e:7a:f0 [ether] on enp1s0
? (192.168.122.90) at 52:54:00:41:02:a1 [ether] on enp1s0
```

Okamžitě je podezřelé jméno `server2`. Po vyzkoušení přihlášení pod loginem `joe` s klíčem `rsa` se podařilo úspěšně přihlásit.

6 motd

Server2 okamžitě přivítá uživatele nesmyslnou Message of the Day:

```
yfojrxxy{nd|d8;k57=:5gg57hh=7<7f>f575k9755j89;j7<;fj;;9j9:jj=5<9::<9j7k:fg=5
```

Po přirovnání ke známému prefixu tajemství lze poznamenat, že zdvojené MOTD obsahuje zdvojené symboly na stejných indexech jako `tajemstvi_?_`, jedná se o symboly `t` a `_`. Lze tedy usoudit, že se jedná o monoalfabetickou substituční šifru. Po další analýze si lze povšimnout, že jsou první symboly posunuty o stejné pořadí v abecedě, jelikož ovšem šifra obsahuje i zvláštní symboly, usoudil jsem, že se jedná o posunutí v rámci bytu neboli ASCII. Po posunutí zpět vznikne tajemství:

tajemstvi_w_36f028580bb02cc8272a9a020f4200e346e276ae664e45ee80745574e2f5ab80

7 Závěr

Objevil jsem 5 ze 6-ti tajemství, zvládl se dostat na dva servery včetně počátečního. Zranitelnosti sítě jsem nezkoumal, ovšem za tímto účelem bych použil nástroj **nmap**. Je možné, že bych takto objevil další dostupný server.